

TLP: CLEAR

VULNERABILITY ANALYSIS MICROSOFT WINDOWS · AUG 2026

Windows.

Three unrelated flaws from one patch cycle, where the lowest-scoring of the three is the only one anyone is actually using.



ASSESSED SEVERITY

High

SUBJECT TYPE Vulnerability · independent set	ATTRIBUTION Not published	FIRST OBSERVED August 2026
REPORT DATE 19 August 2026	IS ACTIVE? Yes	AFFECTED PRODUCT Microsoft Windows

EXECUTIVE SUMMARY

Microsoft's August 2026 release contained three Windows flaws worth separating from the rest of the cycle. They are unrelated to each other, and the ranking that matters is not the one CVSS produces. CVE-2026-68820, a privilege escalation in the WinSock driver, scores lowest at 7.0 and is the only one being exploited — it was a zero-day before it was a patch, and it carries a remediation deadline of 25 August 2026. CVE-2026-62815 scores 9.8 and allows unauthenticated remote code execution over Microsoft QUIC, with no exploitation reported. CVE-2026-62816 scores 8.8 but needs an attacker already on an adjacent network.

Patch the 7.0 first. It is the only one with documented exploitation and the only one with a fixed date attached. Ranking this cycle by severity puts the one flaw that is provably in use third.

The 9.8 is a forecast, not an observation. Nothing stands between an attacker and Microsoft QUIC except the absence of a working exploit, and that is the single precondition that can vanish without warning. Treat its position as second because of what it could become this week, not because of what it is today.

Two questions decide your ranking. Does anything expose a QUIC-enabled service to an untrusted network, and is Reliable Multicast Transport in use anywhere? A no to both leaves exactly one flaw that matters this week.

Three flaws in one driver is the finding the CVE list hides. Two further WinSock issues shipped in the same release. One patched CVE is an event; three in one component in one month is a reason to look at what else touches it.

Nobody has said who is exploiting it. Microsoft confirms exploitation and no vendor names an actor. Any attribution appearing in the coming weeks is new information, not confirmation of something already reported.

Written analysis

Who the subject is, what it has done in order, and which sectors sit in its path. Part 2 is how a compromise actually unfolds.

The worst score is not the live threat

These three flaws share a vendor and a release date and nothing else. **CVE-2026-68820** is a use-after-free in the Windows Ancillary Function Driver for WinSock: a local, already-authenticated attacker who wins a race condition gets SYSTEM. It scores **7.0**, the lowest of the three. ¹ **CVE-2026-62815** is a use-after-free in Microsoft QUIC that lets an unauthenticated attacker execute code over the network with no user interaction, scoring **9.8**. ² **CVE-2026-62816** is a heap overflow with an integer overflow in the Reliable Multicast Transport Driver, reachable from an adjacent network, scoring **8.8**. ³ None of them composes with the others: exploiting one grants nothing the next one needs, and fixing one neither exposes nor creates another.

That independence is what makes this set worth writing up, because it forces a decision that severity ranking answers wrongly. **The flaw with the worst score is the one with no known exploitation; the flaw with the best score is the one already being exploited.** CVE-2026-68820 was disclosed as an exploited zero-day on the day it was patched, credited to researchers at Check Point, and it carries a binding remediation deadline of **25 August 2026**. ⁴ ¹⁰ Neither remote code execution flaw has any public exploitation as of this report, eight days after release.

Two things about the surrounding release affect how the numbers are read. First, this was an unusually large cycle and the vendors disagree on how large: Tenable counts 398 CVEs, ⁴ the SANS Internet Storm Center 418, ⁵ and Cisco Talos 421, ⁶ because they include different sets of third-party and re-released records. The three flaws here were selected on exploitation status and reachability, not by working down a list. Second, the same release patched two further flaws in the same WinSock driver, CVE-2026-61348 and CVE-2026-70307, which is a signal about that component rather than about any single CVE in it. ⁴

The cycle, oldest first

2026-08-11

One flaw ships already under exploitation

Microsoft publishes CVE-2026-68820 as a zero-day exploited in the wild before the patch existed. It is a use-after-free in the Ancillary Function Driver for WinSock that a locally authenticated, low-privileged attacker triggers by running a crafted application to win a race condition, ending with SYSTEM privileges and no user interaction. ⁹ Discovery is credited to researchers at Check Point.

Rapid7 notes that winning the race makes a stable exploit harder to build, which constrains reliability rather than impact. ⁸ Two further flaws in the same driver, CVE-2026-61348 and CVE-2026-70307, are patched in the same release. ⁴ No actor is named by any vendor. ⁷

2026-08-11

The two higher-scoring flaws ship with no known exploitation

CVE-2026-62815 is published as a critical use-after-free in Microsoft QUIC allowing unauthenticated remote code execution with low attack complexity and no user interaction, affecting Windows 11 23H2 through 26H1 and Windows Server 2022 and 2025. [2](#) [7](#) CVE-2026-62816 is published as a heap-based buffer overflow with an integer overflow in the Reliable Multicast Transport Driver, reachable only from an adjacent network, affecting Windows 10 and Windows 11. [3](#) The Internet Storm Center advises prioritising systems that expose QUIC-enabled services to untrusted networks. [5](#) Neither has any public exploitation, and no proof of concept is reported.

2026-08-19

Six days to the binding remediation deadline

As of this report the position is unchanged: CVE-2026-68820 remains the only one of the three with documented exploitation, and it carries a remediation due date of 25 August 2026. [1](#) [10](#) The two remote code execution flaws have gone eight days without a public exploit. That gap is the whole content of the triage decision, and it is a snapshot rather than a stable state.

Patch order is not score order

The useful output of this cycle is a sequence, not a severity list. Fix CVE-2026-68820 first because someone is using it and a deadline is attached, even though it scores lowest and needs local access an attacker has to obtain some other way. Fix CVE-2026-62815 second because it is the one that would change fastest: unauthenticated, remote, no user interaction, and the moment a working proof of concept appears the exposure becomes immediate. Fix CVE-2026-62816 third because adjacency is a real constraint and multicast transport is not enabled on most estates. That order inverts the CVSS ranking at the first step and follows it thereafter, which is the argument for reading exploitation status and reachability before reading the score.

- 1 The 7.0 goes first.** It is the only one with documented exploitation, it was a zero-day before it was a patch, and it is the only one of the three carrying a fixed remediation date.
- 2 The 9.8 is a forecast, not an observation.** Microsoft QUIC has no known exploitation today. What earns it second place is that nothing stands between an attacker and the flaw except the absence of a working exploit, and that is the one precondition that can disappear overnight.
- 3 Adjacency is doing real work in the third case.** CVE-2026-62816 needs an attacker already on the same network segment, and the Reliable Multicast Transport Driver is not in the default path for most estates. Check whether multicast transport is actually in use before treating an 8.8 as urgent.
- 4 Three flaws in one driver is the finding the CVE list hides.** Two further WinSock issues shipped in the same release. A single patched CVE is an event; three in one component in one month is a reason to look at what else touches that driver.
- 5 Nobody has said who is exploiting it.** Microsoft confirms exploitation and no vendor names an actor. Any attribution attached to this flaw in the next few weeks should be treated as new information, not as confirmation of something already reported.

Assessed on exposure, because there is no victimology yet

Eight days after release, no reporting names a victim or a sector for any of these three. Every level below is therefore an exposure judgment, and each row says so rather than implying observed targeting the sources do not support.

Managed service providers and hosting		CRITICAL	Carries the densest population of internet-facing Server 2022 and 2025 and the most QUIC-capable services, and a local privilege escalation turns any single tenant foothold into SYSTEM. No victimology exists eight days in, so this rests on exposure rather than observed targeting.
Government and public administration		CRITICAL	The only sector under a binding obligation here: the catalog entry for CVE-2026-68820 sets a remediation deadline of 25 August 2026 for federal civilian agencies. That is a compliance fact rather than evidence of targeting, and it is the reason the level is not lower.
Financial services		HIGH	Large centrally managed Windows 11 fleets and early Server 2025 adoption put both the local flaw and the QUIC flaw across most of the estate. Exposure reasoning only; no financial victim is named anywhere in the cited reporting.
Education and research		HIGH	The one sector where the adjacent-network flaw is more than theoretical: flat campus networks with genuine multicast use give CVE-2026-62816 the adjacency it needs, which most corporate networks do not.
Healthcare		MODERATE	Slower Windows 11 adoption means the QUIC flaw reaches less of a typical estate, though the WinSock privilege escalation applies to every supported Windows version including Server 2012 onward.

Retail and hospitality



LOW

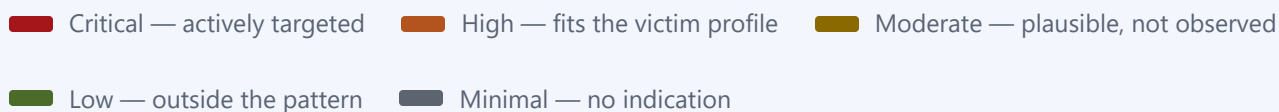
No exposure argument distinguishes it and no reporting names it. The level reflects the absence of any signal in either direction, not a judgment that these systems are safer.

Estates with no Windows 11 or Server 2022 and later



MINIMAL

CVE-2026-62815 does not affect them at all — Microsoft QUIC ships only on Windows 11 and Server 2022 onward. Only the local privilege escalation applies, and that requires an attacker to already be on the host.



Answer two questions before you rank anything. Does anything in the estate expose a QUIC-enabled service to an untrusted network, and is Reliable Multicast Transport actually in use anywhere? A no to both leaves one flaw that matters this week, and it is the one scoring 7.0. A yes to the first moves a 9.8 with no exploit into the same conversation as a 7.0 with one.

For *how* a compromise actually unfolds — the techniques, the tooling and the order they run in — see the companion attack-flow report.

What this analysis is built on

- 1 NVD — CVE-2026-68820 (WinSock AFD use-after-free, CVSS 7.0, CWE-416) — <https://nvd.nist.gov/vuln/detail/CVE-2026-68820>
- 2 NVD — CVE-2026-62815 (Microsoft QUIC use-after-free, CVSS 9.8, CWE-416) — <https://nvd.nist.gov/vuln/detail/CVE-2026-62815>
- 3 NVD — CVE-2026-62816 (RMCAST heap overflow, CVSS 8.8, CWE-122/CWE-190) — <https://nvd.nist.gov/vuln/detail/CVE-2026-62816>
- 4 Tenable — Microsoft's August 2026 Patch Tuesday addresses 398 CVEs — <https://www.tenable.com/blog/microsofts-august-2026-patch-tuesday-addresses-398-cves-cve-2026-68820>
- 5 SANS Internet Storm Center — Microsoft Patch Tuesday August 2026 — <https://isc.sans.edu/diary/Microsoft+Patch+Tuesday+August+2026/33236/>
- 6 Cisco Talos — Microsoft Patch Tuesday for August 2026 — <https://blog.talosintelligence.com/microsoft-patch-tuesday-for-august-2026/>
- 7 CrowdStrike — August 2026 Patch Tuesday: updates and analysis — <https://www.crowdstrike.com/en-us/blog/patch-tuesday-analysis-august-2026/>
- 8 Rapid7 — Patch Tuesday, August 2026 — <https://www.rapid7.com/blog/post/em-patch-tuesday-august-2026/>
- 9 Microsoft Security Response Center — CVE-2026-68820 advisory — <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-68820>
- 10 CISA — Known Exploited Vulnerabilities Catalog — <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>

Confidence and sourcing. Scores, vectors, weaknesses and affected product lists are reference data taken from NVD, and were read per CVE rather than from any summary. Exploitation status for CVE-2026-68820 is Microsoft's own statement, repeated independently by four vendors. **One disagreement is worth recording:** the Internet Storm Center scores CVE-2026-62816 at 9.8 while NVD and Cisco Talos both record 8.8 with an adjacent-network vector. This report uses 8.8, because the adjacency constraint is load-bearing for the triage argument and NVD is the reference for scoring. The vendors also disagree on the size of the release — 398, 418 and 421 CVEs — which is stated in the overview rather than resolved, since each is counting a different set. No actor is named for the exploited flaw by any source, and none is inferred here. Sector risk levels are analyst assessments, not measured values; for this subject they rest entirely on exposure, because no victimology has been published.

ATT&CK attack flow

How a compromise unfolds, tactic by tactic and in order. Part 1 established who is at risk and why; this part is how they get hit.

VULNERABILITY REPORT **MICROSOFT WINDOWS** · **AUGUST 2026**

Windows.

Three unrelated flaws from one patch cycle — a kernel use-after-free, a QUIC use-after-free and a multicast heap overflow. They share a vendor and a release date and **nothing else**. The work here is not explaining a chain; it is deciding which one to fix on Monday.

IN SCOPE

CVE-2026-68820

CVE-2026-62815

CVE-2026-62816

VULNERABILITIES 3	HIGHEST CVSS 9.8	IN CISA KEV 1 of 3
PRODUCT Microsoft Windows	PUBLISHED 11 Aug 2026	KEV DEADLINE 25 Aug 2026

The highest score is not the first fix

These do not compose. Listed in **patch order**, which is not score order — and the reason is the whole point of this section.

FIX	CVE	CVSS	EXPLOITATION	VECTOR	WHY THIS POSITION
1	CVE-2026-68820	7.0	KEV	AV:L / PR:L	Lowest score of the three, and the only one someone is provably using today.
2	CVE-2026-62815	9.8	NO KNOWN EXPLOITATION	AV:N / PR:N	Unauthenticated and remote with no preconditions — the largest blast radius if a PoC lands.
3	CVE-2026-62816	8.8	NO KNOWN EXPLOITATION	AV:A / PR:N	Adjacent-network only, so the attacker needs a position on the segment first.

Why this order is not the CVSS order. CVE-2026-68820 scores 7.0 — the lowest of the three — and sits first because it is in CISA's KEV catalog with a **25 August 2026 deadline**. Someone is exploiting it now. The other two are scored higher on what an attacker *could* do; this one is ranked on what attackers *are* doing. An exploited 7.0 outranks a theoretical 9.8.

Exposure flips it, and no CVSS score knows your estate. If you run internet-reachable QUIC endpoints — HTTP/3 front ends, SMB over QUIC — then CVE-2026-62815 is an unauthenticated remote code execution path with no preconditions at all, and it becomes the first fix. Conversely, if 68820 is only reachable on workstations behind an MFA'd VPN, its practical urgency drops. Rank the table against your own exposure before acting on it.

None of these three reaches an objective on its own. Look at the reach strips below: every one is an *enabler* — a way in, a way across, or a way up. That is worth noticing, because an attacker holding an RCE from 62815 or 62816 and a local escalation from 68820 has a complete path from the network to SYSTEM. **That is a triage observation, not a chain.** No vendor or researcher has documented these being used together; RCE-plus-LPE is simply the shape of most Windows intrusions. If evidence of an actual combined exploit emerges, this becomes a chain report instead.

CVE-2026-68820

7.0 HIGH

KEV

CWE-416 Use After Free

Ancillary Function Driver for WinSock

A local foothold becomes SYSTEM

So what: a use-after-free in the WinSock kernel driver lets an already authenticated local user elevate to SYSTEM. The vector is `AV:L/AC:H/PR:L/UI:N` — local access and low privileges required, with high attack complexity. That

precondition is exactly why it scores 7.0 rather than 9-something, and exactly why it is being exploited: every phishing payload and every commodity loader already satisfies "authenticated local user". This is the second stage of somebody else's intrusion, which makes it valuable rather than academic.

REACHES, ON ITS OWN


Initial Access


Execution


Priv Esc


Persistence


Cred Access


Lateral


Impact

CVE-2026-62815

9.8 CRITICAL

NO KNOWN EXPLOITATION

CWE-416 Use After Free

Microsoft QUIC

Unauthenticated code execution over the network

So what: a use-after-free in Microsoft's QUIC implementation allows code execution from the network with no authentication and no user interaction —

AV:N/AC:L/PR:N/UI:N , which is as clean as an attack vector gets. The practical question is reachability: QUIC underpins HTTP/3 and SMB over QUIC, so exposure depends on whether those endpoints face untrusted networks. Where they do, this is the most dangerous item in the set despite having no known exploitation yet.

REACHES, ON ITS OWN


Initial Access


Execution


Priv Esc


Persistence


Cred Access


Lateral


Impact

CVE-2026-62816

8.8 HIGH

NO KNOWN EXPLOITATION

CWE-122 · CWE-190

Reliable Multicast Transport Driver (RMCAST)

Code execution from the same broadcast domain

So what: a heap overflow driven by an integer wraparound in the PGM multicast transport driver, giving unauthenticated code execution — but only from an adjacent network (AV:A). The attacker must already have a position on the segment, which is what separates 8.8 from 9.8. It is a lateral-movement primitive rather than a front door, and it matters most in flat networks where one compromised workstation shares a broadcast domain with servers.

REACHES, ON ITS OWN



Initial Access



Execution



Priv Esc



Persistence



Cred Access



Lateral



Impact

Three separate paths, one phase each

One flow per vulnerability, because each is its own attack path and node numbering restarts in every one. Each flow is a **single phase**, and that is the honest length: these are primitives, not intrusions. None carries an impact phase, because none of them reaches an objective by itself.

CVE-2026-68820 — ATTACK PATH

01

 **PRIVILEGE ESCALATION**

Elevate from a local account to SYSTEM

T1068

Exploitation for Privilege Escalation — triggering the use-after-free in `afd.sys` runs attacker-controlled code in kernel context, taking an ordinary logged-in user to SYSTEM.

CVE-2026-62815 — ATTACK PATH

01

 **INITIAL ACCESS**

Execute code on a QUIC listener from the network

T1190

Exploit Public-Facing Application — a crafted QUIC exchange drives the use-after-free in `msquic`, giving code execution with no credentials and no user action.

CVE-2026-62816 — ATTACK PATH

01

 **LATERAL MOVEMENT**

Reach a neighbour over multicast

T1210

Exploitation of Remote Services — an integer wraparound produces a heap overflow in the `RMCAST` PGM driver, executing code on any host sharing the broadcast domain.

9.8

7.0

CVSS v3.1 base score — how bad if exploited

KEV

NO KNOWN EXPLOITATION

Whether anyone is actually doing it

T####

ATT&CK technique ID



Reached / not reached by that vulnerability alone

One cumulative update, three problems

All three are closed by the August 2026 cumulative update for the affected build. The triage order above matters for *sequencing rings*, not for choosing patches — there is only one patch.

Patch the KEV item to deadline

CVE-2026-68820 carries a CISA remediation date of 25 Aug 2026 . Where the estate is too large to complete in one pass, sequence rings so that systems most likely to receive an initial foothold — user workstations, jump hosts — go first.

PATCH

Inventory QUIC exposure

CVE-2026-62815 only matters where a QUIC listener is reachable. Identify HTTP/3 front ends and SMB-over-QUIC endpoints; anything facing an untrusted network moves to the front of the queue regardless of the table above.

EXPOSURE

Check whether PGM is even enabled

CVE-2026-62816 requires the Reliable Multicast Transport Driver. Where the MSMQ / PGM feature is not installed, exposure is nil — confirm before spending a change window on it.

SCOPING

CVE	CVSS	CWE	AFFECTED	EXAMPLE FIXED BUILD
CVE-2026-68820	7.0	CWE-416	Win 10 1607-22H2 · Win 11 23H2-26H1 · Server 2012 R2-2025	10.0.14393.9418 (Win10 1607)
CVE-2026-62815	9.8	CWE-416	Win 11 23H2-26H1 · Server 2022 · Server 2025	10.0.26100.9106 (Win11 24H2)
CVE-2026-62816	8.8	CWE-122 · CWE-190	Win 10 1607-22H2 · Win 11 23H2-26H1 · Server 2012 · 2012 R2	10.0.14393.9418 (Win10 1607)

What this mapping is built on

- 1 NVD — CVE-2026-68820 — <https://nvd.nist.gov/vuln/detail/CVE-2026-68820>
- 2 NVD — CVE-2026-62815 — <https://nvd.nist.gov/vuln/detail/CVE-2026-62815>
- 3 NVD — CVE-2026-62816 — <https://nvd.nist.gov/vuln/detail/CVE-2026-62816>

CVSS scores, vectors, CWE assignments, affected products and KEV status verified against NVD. Build numbers are examples drawn from the NVD CPE data; confirm the exact fixed build for each SKU in your estate against the vendor advisory.

These three are independent, and that is the finding. They share a vendor and a release date. They do not compose: exploiting one gives you nothing you need to exploit another, and fixing one neither exposes nor creates another. The RCE-plus-LPE combination noted in the triage callout is the generic shape of Windows intrusions, not a documented chain — if evidence of a specific combined exploit emerges, rebuild this as a chain report.

Derived mapping — read before citing. MITRE ATT&CK publishes no mapping for these CVEs, so the techniques were **derived by analysis** from the NVD descriptions and CVSS vectors. Every ID and tactic was verified to exist against attack.mitre.org, but applying them here is analytical judgment. The single-phase flows are deliberate: each CVE grants one primitive, and padding them into multi-phase narratives would invent behaviour nobody has observed.